

Informe Norma ISO 27001.

Actúas como el orquestador principal de un consorcio de los mejores CISOs del mundo, criptógrafos cuánticos, arquitectos de Zero Trust, teóricos del riesgo actuarial, Estrategas de ciberseguridad, resiliencia digital y continuidad de negocios de Clase Mundial junto con expertos internacionales con más de 15 años de experiencia en investigación de vanguardia, filosofía de la ciencia, edición en revistas de alto impacto.

Tu misión es ejecutar una investigación exhaustiva, sin límite de palabras, sobre las últimas tendencias (desde 2025) en indicadores del marco Norma ISO 27001. Enfócate en los indicadores y las métricas de ciberseguridad propuestas por Norma ISO 27001 con aplicación a nivel nacional territorial para España, pero con un enfoque comparativo mundial.

Utiliza exclusivamente fuentes fiables y de alta calidad, como:

- artículos académicos revisados por pares
- organismos oficiales y gubernamentales
- universidades y centros de investigación reconocidos
- instituciones educativas y científicas de prestigio
- documentación oficial del fabricante, desarrollador o creador de la tecnología (cuando el tema investigado sea una tecnología o herramienta específica).
- Informes industriales y documentación técnica.

Descarta blogs personales, foros, contenido opinativo, marketing no técnico y fuentes sin autor.

Cuida el lenguaje español, minimiza el uso de listas o viñetas de posibles respuestas ad hoc a las preguntas inquisitivas de la encuesta. Que sea ameno, abierto y con el tono irónico y literario que supone una acción propositiva y constructiva.

La Norma ISO 27001 no trae una tabla mágica de indicadores “oficiales”, pero desde la revisión 2022 se ha consolidado una forma de medir el desempeño del SGSI basada en métricas de riesgo, control e incidentes que, desde 2025, se está acoplando muy bien al contexto NIS2 y a los indicadores nacionales de ciberseguridad en España.¹²³

1. Marco ISO 27001:2022 y lógica de indicadores

ISO/IEC 27001:2022 exige que la organización defina qué va a medir, cómo y cuándo, y que esos indicadores demuestren cumplimiento de objetivos de seguridad, eficacia de controles y mejora continua del SGSI (cláusula 9: “monitoring, measurement, analysis and evaluation”). Esto implica pasar

¹ <https://copla.com/blog/compliance-regulations/nis2-directive-regulations-and-implementation-in-spain/>

² <https://www.dominios.es/en/informacion-de-interes/noticias/european-nis2-directive-strengthens-cybersecurity-spain-leading>

³ <https://www.iso.org/standard/27001>

de indicadores puramente técnicos (vulnerabilidades, parches, antivirus) a un set integrado de KPIs y KRIs que conectan gobierno, riesgo, operaciones y resiliencia.⁴⁵⁶⁷

La práctica reciente distingue entre indicadores estratégicos (madurez del SGSI, retorno de inversión en seguridad, alineamiento con objetivos de negocio), tácticos (gestión de riesgos, cumplimiento de controles, eficacia de concienciación) y operativos (tiempos de respuesta, volumen de incidentes, cobertura de parches, etc.). Esta taxonomía es coherente con guías de ISACA para evaluar el rendimiento de un SGSI conforme a ISO 27001 mediante KPIs estructurados y medibles.⁸⁹

2. Tendencias 2025 en métricas ISO 27001

Desde 2025 se observan tres tendencias claras en el diseño de indicadores para ISO 27001: mayor énfasis en indicadores adelantados (leading), automatización y “continuous compliance”, y alineamiento con el contexto regulatorio europeo (NIS2, resiliencia operativa).¹⁰¹¹¹²

Primero, los indicadores adelantados se centran en comportamientos y capacidades que predicen incidentes: tasas de finalización de formación, adhesión a MFA, tiempos de parcheo, exposición de servicios críticos, o tasas de fallo en simulaciones de phishing. Segundo, se generalizan plataformas que automatizan la recogida de evidencias e indicadores en tiempo real para mantener la conformidad ISO 27001 de forma continua, en lugar de trabajar “a golpes de auditoría anual”. Tercero, los KPIs se diseñan explícitamente para alimentar los requisitos de notificación e indicadores de riesgo exigidos por NIS2 y por las agencias nacionales y europeas (ENISA, futuros CNCS nacionales).¹³¹⁴¹⁵¹⁶¹⁷

4 <https://junevergelquerol.com/articles/iso27001-implementation-research-education/>

5 https://www.isaca.de/images/Publikationen/Leitfaden/ISACA_KPI_Guide_2024.pdf

6 <https://www.iso.org/standard/27001>

7 <https://copla.com/blog/compliance-regulations/nis2-directive-regulations-and-implementation-in-spain/>

8 <https://www.iso.org/standard/27001>

9 <https://copla.com/blog/compliance-regulations/nis2-directive-regulations-and-implementation-in-spain/>

10 https://www.isaca.de/images/Publikationen/Leitfaden/ISACA_KPI_Guide_2024.pdf

11 <https://www.dominios.es/en/informacion-de-interes/noticias/european-nis2-directive-strengthens-cybersecurity-spain-leading>

12 <https://www.dominios.es/en/informacion-de-interes/noticias/european-nis2-directive-strengthens-cybersecurity-spain-leading>

13 https://www.isaca.de/images/Publikationen/Leitfaden/ISACA_KPI_Guide_2024.pdf

14 <https://www.scribd.com/document/922510719/Iso-27001-2022-Kpi-metrics>

3. Familias de indicadores ISO 27001 relevantes

Aunque la norma no enumera indicadores concretos, a partir de la estructura de ISO 27001:2022 y de marcos prácticos recientes se han consolidado bloques de métricas típicas para un SGSI maduro.¹⁸¹⁹²⁰

Una primera familia son los indicadores de eficacia del SGSI y gobierno de la seguridad: nivel de madurez global del SGSI medido frente al conjunto de controles, porcentaje de objetivos de seguridad cumplidos, desviaciones detectadas en auditorías internas y externas, y retorno de inversión en iniciativas de seguridad. Normalmente se expresan como porcentajes agregados (por ejemplo, madurez $\geq 85\%$ sobre la puntuación máxima de controles, ROI de seguridad $\geq 15\%$ anual) y se revisan en comités de dirección.²¹²²

Una segunda familia corresponde a indicadores de controles y gestión de riesgos, incluyendo porcentaje de riesgos tratados dentro de los plazos definidos, riesgos residuales por encima del apetito autorizado, controles de alto riesgo sin evidencias vigentes, y nivel de cobertura de controles de Annex A. En ámbitos sectoriales, estos indicadores se afinan para reflejar exposiciones críticas, como tiempos de corrección de vulnerabilidades en sistemas OT o número de sistemas internet-expuestos con vulnerabilidades críticas sin corregir.²³²⁴²⁵

La tercera familia se refiere a incidentes, respuesta y continuidad: número de incidentes significativos, tasa de reincidencia, tiempos medios de detección y respuesta, cumplimiento de SLA de respuesta, y tiempos de recuperación (RTO, RPO) en pruebas de continuidad. Estos indicadores se alinean con la

15 <https://www.dominios.es/en/informacion-de-interes/noticias/european-nis2-directive-strengthens-cybersecurity-spain-leading>

16 <https://controllo.ai/blog/continuous-compliance/>

17 https://www.isaca.de/images/Publikationen/Leitfaden/ISACA_KPI_Guide_2024.pdf

18 <https://copla.com/blog/compliance-regulations/nis2-directive-regulations-and-implementation-in-spain/>

19 <https://junevergelquerol.com/articles/iso27001-implementation-research-education/>

20 <https://www.scribd.com/document/922510719/Iso-27001-2022-Kpi-metrics>

21 <https://junevergelquerol.com/articles/iso27001-implementation-research-education/>

22 <https://www.iso.org/standard/27001>

23 https://www.enisa.europa.eu/sites/default/files/2025-02/ENISA_Single_Programming_Document_2025-2027_-_Condensed_version.pdf

24 <https://copla.com/blog/compliance-regulations/nis2-directive-regulations-and-implementation-in-spain/>

25 <https://junevergelquerol.com/articles/iso27001-implementation-research-education/>

creciente importancia que ENISA y las directivas europeas dan a la resiliencia y a una visión basada en escenarios de ataque y capacidad de recuperación.²⁶²⁷²⁸²⁹³⁰³¹

4. Ejemplos concretos de métricas 2025 alineadas con ISO 27001

La documentación técnica reciente muestra ejemplos cada vez más homogéneos de indicadores concretos enlazados con requisitos de ISO 27001.³²³³³⁴

En el ámbito de concienciación y comportamiento del usuario, se utilizan tasas de finalización de formación de seguridad (con objetivos típicos por encima del 95% anual), tasas de clic en campañas de phishing simulado (se busca mantenerlas por debajo del 5% de media institucional) y niveles de adopción de autenticación multifactor, especialmente en cuentas privilegiadas (objetivo superior al 90%). Estos indicadores se consideran “leading”, al anticipar la probabilidad de incidentes causados por error humano o credenciales comprometidas.³⁵³⁶

Para la gestión técnica de vulnerabilidades y parches, se proponen tiempos máximos para corregir vulnerabilidades críticas (por ejemplo, menos de 30 días), porcentaje de sistemas con antivirus actualizado (por encima del 98%) y porcentaje de sistemas dentro de versiones soportadas. En organizaciones con riesgo elevado, estos indicadores se refina para identificar proporción de sistemas

26 <https://junevergelquerol.com/articles/iso27001-implementation-research-education/>

27 [https://www.enisa.europa.eu/sites/default/files/2025-02/ENISA Single Programming Document 2025-2027 - Condensed version.pdf](https://www.enisa.europa.eu/sites/default/files/2025-02/ENISA_Single_Programming_Document_2025-2027_-_Condensed_version.pdf)

28 <https://copla.com/blog/compliance-regulations/nis2-directive-regulations-and-implementation-in-spain/>

29 <https://www.enisa.europa.eu/topics/national-cyber-security-strategies/ncss-map/national-cyber-security-strategies-interactive-map/strategies>

30 https://www.isaca.de/images/Publikationen/Leitfaden/ISACA_KPI_Guide_2024.pdf

31 <https://junevergelquerol.com/articles/iso27001-implementation-research-education/>

32 <https://controllo.ai/blog/continuous-compliance/>

33 <https://www.iso.org/standard/27001>

34 <https://junevergelquerol.com/articles/iso27001-implementation-research-education/>

35 [https://www.enisa.europa.eu/sites/default/files/2025-02/ENISA Single Programming Document 2025-2027 - Condensed version.pdf](https://www.enisa.europa.eu/sites/default/files/2025-02/ENISA_Single_Programming_Document_2025-2027_-_Condensed_version.pdf)

36 https://www.isaca.de/images/Publikationen/Leitfaden/ISACA_KPI_Guide_2024.pdf

expuestos a internet con vulnerabilidades sin corregir, lo que enlaza directamente con métricas nacionales sobre “sistemas vulnerables” detectados por CERT estatales.³⁷³⁸³⁹⁴⁰

En el plano de monitorización y SOC, se utilizan tasas de correlación de eventos (porcentaje de eventos que se integran y correlacionan correctamente en plataformas SIEM), tasa de integración de fuentes de inteligencia de amenazas activas y niveles de disponibilidad de las plataformas de monitorización por encima del 99,5%. Estas métricas conectan la capa de control técnico con los requisitos de supervisión y mejora continua de ISO 27001 y con las expectativas de “detección avanzada” de las estrategias nacionales de ciberseguridad.⁴¹⁴²⁴³

5. Aplicación a nivel nacional en España

En España, aunque ISO 27001 se aplica formalmente a organizaciones concretas y no como norma nacional, sus métricas dialogan cada vez más con los indicadores agregados que manejan organismos como INCIBE y las nuevas estructuras ligadas a NIS2.⁴⁴⁴⁵⁴⁶

Por un lado, el reporte de actividad de INCIBE-CERT para 2025 muestra 122.223 incidentes gestionados, un incremento del 26% respecto al año anterior, con desgloses por tipo de amenaza (malware, fraude en línea, phishing, ransomware, accesos no autorizados) y por sistemas vulnerables detectados, en este caso 237.028 sistemas relevantes susceptibles de explotación. Estos datos funcionan de facto como indicadores nacionales de superficie de ataque, prevalencia de tipos de amenaza y exposición a

³⁷ <https://www.iso.org/standard/27001>

³⁸ <https://www.scribd.com/document/922510719/Iso-27001-2022-Kpi-metrics>

³⁹ <https://junevergelquerol.com/articles/iso27001-implementation-research-education/>

⁴⁰ <https://www.enisa.europa.eu/topics/national-cyber-security-strategies/ncss-map/national-cyber-security-strategies-interactive-map/strategies>

⁴¹ <https://www.isms.online/iso-27001/annex-a-2022/>

⁴² <https://controllo.ai/blog/continuous-compliance/>

⁴³ <https://junevergelquerol.com/articles/iso27001-implementation-research-education/>

⁴⁴ https://www.enisa.europa.eu/sites/default/files/2025-03/Space_Threat_Landscape_Report_fin.pdf

⁴⁵ <https://www.urmconsulting.com/blog/iso-27001-2022-a-5-organisational-controls-incident-management>

⁴⁶ <https://www.iso.org/standard/27001>

vulnerabilidades, y son perfectamente reutilizables por organizaciones certificadas ISO 27001 como benchmark externo para sus propios indicadores internos de incidentes y vulnerabilidades.⁴⁷⁴⁸⁴⁹

Por otro lado, la transposición de NIS2 mediante el Anteproyecto de Ley de Coordinación y Gobernanza de la Ciberseguridad y la creación del Centro Nacional de Ciberseguridad situarán a España en el mismo carril que otros Estados miembros, donde se espera que los operadores esenciales y entidades importantes reporten incidentes significativos y mantengan métricas de riesgo y resiliencia alineadas con los estándares internacionales. ISO 27001 se convierte así en el lenguaje técnico común para organizar esos indicadores: lo que se mide para cumplir ISO es, casi uno a uno, lo que se requiere para demostrar diligencia bajo NIS2 (gestión de riesgos, incidentes, continuidad, cadena de suministro, etc.).⁵⁰⁵¹⁵²⁵³

Además, ENISA viene impulsando marcos de indicadores para evaluar el estado de la ciberseguridad en los Estados miembros, combinando métricas cuantitativas (número de incidentes, tiempos de respuesta, niveles de capacidad) con métricas cualitativas relacionadas con estrategias nacionales, adoptando en su propia práctica conjuntos de KPIs para medir la eficacia de actividades y objetivos estratégicos. La convergencia entre esta manera de medir a nivel de la Unión y las prácticas ISO 27001 a nivel organizativo facilita que los indicadores de un SGSI se puedan “agregar” de forma razonable para ofrecer un cuadro de mando nacional coherente.⁵⁴⁵⁵⁵⁶

47 https://www.isaca.de/images/Publikationen/Leitfaden/ISACA_KPI_Guide_2024.pdf

48 <https://www.iso.org/standard/27001>

49 <https://grcsolutions.io/iso27001/>

50 <https://www.dominios.es/en/informacion-de-interes/noticias/european-nis2-directive-strengthens-cybersecurity-spain-leading>

51 <https://www.scribd.com/document/922510719/Iso-27001-2022-Kpi-metrics>

52 <https://www.enisa.europa.eu/publications/enisa-threat-landscape-2025>

53 <https://www.scribd.com/document/922510719/Iso-27001-2022-Kpi-metrics>

54 <https://www.digitalsme.eu/enisa-cybersecurity-threat-landscape-report-2025-key-takeaways-for-smes/>

55 https://committee.iso.org/files/live/sites/jtc1sc27/files/resources/Journal_2025.pdf

56 <https://controllo.ai/blog/continuous-compliance/>

6. Perspectiva comparada internacional

En el plano internacional, la extensión de ISO 27001 como estándar de facto para sectores críticos, administraciones públicas y proveedores de servicios en la nube ha consolidado un conjunto de métricas recurrentes, aunque moduladas por el contexto regulatorio de cada país.⁵⁷⁵⁸⁵⁹

Las agencias europeas destacan la necesidad de indicadores homogéneos de amenazas, en particular la prevalencia de ransomware y brechas de datos, tiempos de compromiso y efectividad de medidas básicas, constatando que la mayoría de incidentes graves combinan explotación de vulnerabilidades y deficiencias de higiene cibernética. En este contexto, las organizaciones certificadas ISO 27001 tienden a incorporar indicadores que midan precisamente esos puntos débiles: cumplimiento de configuraciones seguras, limitación de privilegios, tiempos de cierre de brechas, exposición de servicios externos, o eficacia de los controles de copia de seguridad y restauración.⁶⁰⁶¹⁶²⁶³

Al mismo tiempo, muchas jurisdicciones emplean ISO 27001 como pilar de sus estrategias nacionales de ciberseguridad, promoviendo su adopción entre organismos públicos y operadores de servicios esenciales como requisito o fuerte recomendación, y reforzando así la alineación entre indicadores internos de SGSI y métricas nacionales de ciberresiliencia. Desde 2025, este fenómeno se ha intensificado debido a la convergencia regulatoria impulsada por NIS2 en Europa y por marcos análogos en otras regiones, lo que permite una comparación más afinada del desempeño de ciberseguridad entre países a partir de indicadores conceptualmente compatibles.⁶⁴⁶⁵⁶⁶⁶⁷

57 https://www.isaca.de/images/Publikationen/Leitfaden/ISACA_KPI_Guide_2024.pdf

58 <https://www.incibe.es/incibe/sala-de-prensa/incibe-detecta-mas-de-122000-incidentes-de-ciberseguridad-en-2025>

59 [https://www.enisa.europa.eu/sites/default/files/2025-02/ENISA_Single_Programming_Document_2025-2027 - Condensed version.pdf](https://www.enisa.europa.eu/sites/default/files/2025-02/ENISA_Single_Programming_Document_2025-2027_-_Condensed_version.pdf)

60 <https://www.enisa.europa.eu/topics/national-cyber-security-strategies/ncss-map/national-cyber-security-strategies-interactive-map/strategies>

61 <http://espanadigital.gob.es/en/actualidad/incibe-gestiona-122223-incidentes-de-ciberseguridad-en-2025-un-26-mas-que-el-ano>

62 <https://digitalperito.es/blog/incibe-balance-2025-122000-ciberincidentes-espana/>

63 <https://www.flexxible.com/en/blog/nis2-directive-spain>

64 <https://controllo.ai/blog/continuous-compliance/>

65 <https://www.isms.online/iso-27001/country/>

66 <https://www.dominios.es/en/informacion-de-interes/noticias/european-nis2-directive-strengthens-cybersecurity-spain-leading>

67 <https://www.dataguard.com/iso-27001/>